

操作审计日志样例与留存策略

字段规范 · 留存周期 · 导出格式 · SIEM 对接说明

对外可控分发 · 供安全 / 内审评估 · 版本 2026-07-16

置信度说明：本文档基于积木仓 BlockHub 产品当前版本（v2.6）功能撰写，字段定义与留存策略已在内部环境验证，实际部署时以合同约定为准。SIEM 对接支持 Syslog RFC 5424 与 HTTP JSON 两种方式，需在部署前确认目标系统兼容性。

1. 审计目标与不可篡改原则

操作审计日志是积木仓 BlockHub 平台安全合规的基础组件，旨在为信息安全、内审及合规负责人提供可追溯、可核验的操作记录。本日志系统记录所有对平台资源、配置、用户及数据的变更操作，包括管理控制台、API 调用及 SDK 集成场景。审计日志的完整性是保障企业满足等保 2.0、ISO 27001 及 GDPR 等监管要求的关键。

不可篡改原则是本日志系统的核心设计目标。所有日志在生成后即写入只读存储区，任何用户（包括平台管理员）均无法修改或删除已生成的日志条目。日志存储采用追加写（append-only）模式，并基于哈希链（hash chain）技术确保每一条日志与前一条日志的哈希值关联，形成防篡改证据链。该机制已在内部测试环境中通过模拟篡改攻击验证，但实际部署时需结合客户环境的安全策略进行最终确认。

日志的生成时间戳采用 NTP 同步的 UTC 时间，精度为毫秒级。时间戳在写入日志后即被锁定，无法回拨或修改。对于跨时区部署的场景，日志中同时记录 UTC 时间与本地时区偏移量，便于审计人员统一分析。时间同步的准确性依赖于客户网络环境，建议在部署前完成 NTP 服务配置验证。

审计日志的完整性校验由平台后台服务定期执行，校验频率默认为每 15 分钟一次。若检测到哈希链断裂或时间戳异常，系统将触发告警并通知安全管理员。告警方式包括邮件、Webhook 及平台内通知。该校验机制在试点项目中已运行超过 6 个月，未发现误报，但客户需自行评估告警响应流程的时效性。

为满足不同行业的合规要求，积木仓 BlockHub 支持将审计日志导出至外部存储（如 AWS S3、阿里云 OSS 或本地 NAS），导出过程采用 TLS 1.2+ 加密传输。导出的日志文件包含完整哈希链，可用于第三方审计机构独立验证。导出功能需在合同中明确启用，并配置相应的存储桶权限。

本日志系统不记录敏感数据内容（如密码明文、个人身份信息 PII 的完整值），仅记录操作元数据（如操作类型、资源 ID、执行者 ID）。对于涉及数据内容的操作（如数据查询、文件下载），日志中仅记录数据量级与操作结果，不包含具体数据行。该设计旨在平衡审计需求与数据隐私保护，符合 GDPR 及《个人信息保护法》的最小化原则。

2. 覆盖范围与动作分类

积木仓 BlockHub 的操作审计日志覆盖平台所有核心模块，包括但不限于：用户管理、角色权限、应用管理、数据源连接、API 网关、工作流引擎、文件存储、配置中心及监警告警。每个模块的操作均按照统一分类标准记录，确保审计人员能够快速定位特定类型的操作。覆盖范围的详细清单可在产品文档中查询，本文档仅列出主要模块。

操作动作分类采用三级体系：一级分类为操作领域（如用户管理、应用管理），二级分类为操作类型（如创建、修改、删除、查询、授权），三级分类为具体操作名称（如创建用户、修改角色权限）。所有操作均映射到该分类体系，并在日志字段中通过 action_category、action_type 和 action_name 三个字段标识。该分类体系在内部版本迭代中保持向后兼容，新增操作会遵循现有分类规则。

以下为常见操作动作分类示例：用户管理领域包括创建用户、删除用户、修改用户属性、重置密码、锁定账户、解锁账户；应用管理领域包括创建应用、部署应用、停止应用、删除应用、修改应用配置；权限管理领域包括创建角色、删除角色、修改角色权限、绑定用户角色、解绑用户角色。完整分类列表可在附录中查询，或通过平台 API 获取最新版本。

对于 API 调用场景，日志记录包括请求方法（GET/POST/PUT/DELETE）、请求路径、请求参数（仅记录非敏感参数）、响应状态码及响应耗时。API 调用的动作分类自动映射至对应模块的操作类型，例如 POST /api/v1/users 映射为用户管理-创建用户。API 日志的采样率默认为 100%，但客户可根据性能需求调整采样率（最低 10%），调整后需在日志中标记采样率值。

SDK 集成场景的审计日志由客户端 SDK 生成并上报至平台，上报过程采用异步批量方式，默认每 5 秒或每 100 条日志上报一次。SDK 日志包含客户端 IP、设备指纹及 SDK 版本号，便于识别异常来源。SDK 日志的完整性依赖于客户端网络稳定性，若上报失败，日志将在客户端本地缓存最多 24 小时，超时后丢弃。客户需评估该机制对审计完整性的影响。

平台还支持自定义操作分类，允许客户将特定业务操作纳入审计范围。自定义分类需通过平台管理后台配置，配置后系统会自动记录相关操作。自定义分类的日志格式与标准日志一致，但 action_category 字段值为 custom。该功能需在合同中明确启用，并需客户提供操作识别规则（如 API 路径正则表达式）。

3. 字段字典与样例行

每条审计日志包含以下核心字段：log_id（全局唯一 ID，UUID v4 格式）、timestamp（UTC 毫秒级时间戳）、actor_id（执行者用户 ID）、actor_ip（执行者来源 IP）、actor_type（执行者类型：user/api_key/system）、resource_id（操作资源 ID）、resource_type（资源类型：user/app/role/config 等）、action_category（操作领域）、action_type（操作类型）、action_name（操作名称）、result（操作结果：success/failure/denied）、detail（操作详情 JSON 对象）。所有字段均为必填，detail 字段可为空。

以下为一条完整的审计日志样例（JSON 格式）：

```
{ "log_id": "a1b2c3d4-e5f6-7890-abcd-ef1234567890", "timestamp": 1719792000000, "actor_id": "user-001", "actor_ip": "192.168.1.100", "actor_type": "user", "resource_id": "app-123", "resource_type": "application", "action_category": "application_management", "action_type": "modify", "action_name": "modify_app_config", "result": "success", "detail": { "changed_fields": [ "timeout", "max_connections" ], "old_values": { "timeout": 30, "max_connections": 100 }, "new_values": { "timeout": 60, "max_connections": 200 } } }
```

该样例展示了修改应用配置的操作，detail 字段记录了变更前后的具体值。

字段字典中，actor_type 字段用于区分操作发起者类型：user 表示通过 Web 控制台操作的用户，api_key 表示通过 API 密钥调用的自动化脚本，system 表示平台内部系统操作（如定时任务、自动扩缩容）。该字段有助于审计人员识别操作来源，例如发现大量 api_key 类型的失败操作可能表明 API 密钥泄露。actor_type 的取值在平台内部固定，不可自定义。

resource_type 字段的取值列表与平台资源模型一致，包括 user、application、role、permission、datasource、workflow、file、config、alert 等。每个资源类型对应一个资源 ID 格式，例如 application 的 ID 以 app- 开头，datasource 的 ID 以 ds- 开头。资源 ID 的命名规则在平台初始化时确定，后续不可更改。对于批量操作（如批量删除用户），日志中 resource_id 字段记录为 batch 操作 ID，并在 detail 字段中列出所有受影响资源 ID。

detail 字段为 JSON 对象，用于存储操作相关的上下文信息，其内容因操作类型而异。例如，创建用户操作的 detail 包含新用户 ID 与用户名；删除文件操作的 detail 包含文件路径与大小；授权操作的 detail 包含角色 ID 与权限列表。detail 字段的最大长度为 10KB，超过部分将被截断，并在日志中标记 truncated: true。客户需注意，若操作涉及大量数据（如批量授权），detail 可能被截断，建议通过 resource_id 关联其他日志获取完整信息。

日志字段的命名遵循驼峰命名法，所有字段名均为小写字母开头。字段值中，字符串类型使用 UTF-8 编码，时间戳使用 Unix 毫秒时间戳（UTC）。日志输出格式支持 JSON 与 Syslog 两种，默认输出为 JSON。Syslog 格式遵循 RFC 5424，字段映射关系可在附录中查询。客户可根据 SIEM 系统要求选择输出格式，但需注意 Syslog 格式下 detail 字段会被序列化为字符串。

4. 留存、归档与延长选项

积木仓 BlockHub 默认的审计日志留存周期为 180 天（约 6 个月），从日志生成时间开始计算。留存周期结束后，日志将被自动清理，清理过程不可逆。该默认周期适用于大多数等保 2.0 二级系统要求，但对于三级及以上系统或金融、医疗等特殊行业，建议延长留存周期。留存周期的计算基于日志的 timestamp 字段，与日志写入时间无关。

客户可通过平台管理后台调整日志留存周期，可选值为 90 天、180 天、365 天、730 天（2 年）及永久留存。永久留存需额外配置归档存储（如 AWS S3 Glacier 或阿里云 OSS 归档），并会产生额外存储费用。留存周期的调整即时生效，但已生成的日志不受影响（即调整前已存在的日志仍按原周期留存）。调整操作本身也会被记录为审计日志。

日志归档功能支持将历史日志自动导出至外部存储，归档频率可设置为每天、每周或每月。归档文件格式为 JSON Lines（每行一条 JSON 日志），并使用 GZIP 压缩。归档文件命名规则为 audit_log_YYYYMMDD_HHMMSS.gz，其中时间戳为归档任务开始时间。归档任务执行时，系统会先对日志进行完整性校验，校验通过后才导出。归档后的日志在平台内仍可查询，但查询性能可能下降（取决于归档存储的访问延迟）。

延长留存周期需在合同中明确约定，并可能涉及额外费用。例如，将留存周期从 180 天延长至 365 天，需支付存储容量对应的费用。费用计算方式为：日志平均每日生成量（GB）× 延长天数 × 单价。客户可在部署前通过试点环境评估日志生成量，以预估费用。日志生成量受用户数、操作频率及 API 调用量影响，建议在试点期间收集至少 30 天的数据。

对于需要满足监管机构长期留存要求的客户（如证券行业要求 10 年），积木仓 BlockHub 支持将日志导出至客户自建或第三方归档平台，并定期进行完整性校验。导出后的日志管理由客户负责，平台仅提供导出工具与校验接口。导出工具支持增量导出与全量导出两种模式，增量导出基于日志的 timestamp 字段筛选。客户需确保归档平台具备足够的存储容量与访问控制。

日志清理策略支持白名单机制，允许客户指定某些类型的日志（如涉及核心资产的删除操作）永久保留，不受留存周期限制。白名单规则可在管理后台配置，基于 action_category、action_name 或 resource_type 字段。配置白名单后，匹配的日志在清理任务中会被跳过。白名单规则本身也会被记录为审计日志，确保可追溯。

5. 检索、导出与权限

审计日志的检索功能通过平台内置的日志查询界面提供，支持按时间范围、执行者、资源类型、操作类型、操作结果等字段进行精确或模糊查询。查询结果以表格形式展示，默认每页 20 条，最多可调整至每页 100 条。查询性能受日志总量影响，对于超过 1 亿条日志的场景，建议使用导出功能进行离线分析。查询界面支持保存常用查询条件，方便审计人员重复使用。

高级检索功能支持组合条件查询（AND/OR 逻辑）以及正则表达式匹配（仅限 detail 字段）。例如，可查询所有在 2026 年 7 月由 user-001 执行的、操作结果为 failure 的 API 调用日志。高级检索的语法与 Elasticsearch 查询语法兼容，客户可参考平台文档学习。高级检索功能默认关闭，需在合同中启用，启用后可能影响查询响应时间（预计增加 10-20%）。

日志导出功能支持将查询结果导出为 CSV 或 JSON 格式，导出文件大小上限为 100MB（约 50 万条日志）。若查询结果超过 100MB，系统会提示分批次导出。导出任务在后台异步执行，完成后通过邮件或 Webhook 通知用户。导出文件包含查询条件与时间戳，便于审计人员记录导出上下文。导出操作本身也会被记录为审计日志，包括导出者、导出条件及导出文件大小。

审计日志的访问权限由平台的角色权限系统控制，默认只有安全管理员（Security Admin）角色拥有完整访问权限。其他角色（如审计员、运维员）可通过自定义权限策略授予部分访问权限，例如仅允许查看特定资源类型的日志。权限策略支持基于字段级别的访问控制（如隐藏 actor_ip 字段），但需在合同中明确配置。权限变更操作同样被记录为审计日志。

对于多租户场景（如集团客户），每个租户只能查看本租户的审计日志，租户管理员无法查看其他租户的日志。

平台超级管理员（Super Admin）可查看所有租户的日志，但该权限需在合同中明确授予，并需遵守客户内部审批流程。超级管理员的日志查看行为也会被记录，确保透明性。

日志检索与导出功能均支持审计日志本身的查询，即可以查询谁在何时查询了审计日志。该功能用于满足合规要求中的“审计日志访问审计”。查询审计日志的权限默认仅授予安全管理员，且不可委派。该功能在平台内部测试中已验证，但客户需自行评估是否符合其内部审计策略。

6. SIEM / Syslog 对接

积木仓 BlockHub 支持将审计日志实时转发至客户现有的 SIEM 系统，支持两种对接方式：Syslog（RFC 5424）和 HTTP JSON Webhook。Syslog 方式适用于传统 SIEM 系统（如 Splunk、QRadar、ArcSight），HTTP JSON 方式适用于云原生 SIEM 系统（如 Datadog、Sumo Logic、自建 ELK）。两种方式均支持 TLS 加密传输，默认端口为 6514（Syslog）和 443（HTTP）。

Syslog 对接配置需在平台管理后台填写 SIEM 服务器地址、端口及协议（TCP/UDP）。平台支持将日志字段映射至 Syslog 标准字段，例如 timestamp 映射为 Syslog 的 TIMESTAMP，actor_id 映射为 APP-NAME，action_name 映射为 MSGID。映射规则可自定义，但需确保 SIEM 端能正确解析。Syslog 消息的最大长度为 8KB，超过部分将被截断，并在消息末尾添加 [TRUNCATED] 标记。

HTTP JSON 对接方式中，平台将审计日志以 POST 请求发送至客户指定的 Webhook URL，请求头包含 Content-Type: application/json 及自定义认证令牌（Bearer Token）。每次请求包含一条或多条日志（批量发送），批量大小可在 1-100 条之间配置。请求超时时间默认为 10 秒，失败重试次数为 3 次，重试间隔为 5 秒。若所有重试均失败，日志将被丢弃，并记录一条系统告警。

SIEM 对接的日志过滤功能允许客户仅转发特定类型的日志，以减少 SIEM 系统的存储压力。过滤条件基于日志字段（如 action_category、result），支持包含与排除规则。例如，可配置仅转发操作结果为 failure 的日志，或排除所有查询操作的日志。过滤规则在平台端生效，不影响本地存储的日志完整性。过滤规则配置本身也会被记录为审计日志。

对接后的日志格式与平台内部格式一致，但可通过配置添加额外字段，如客户自定义标签（tag）或环境标识（environment）。这些额外字段在日志的 detail 对象中存储，键名为 custom_fields。例如，可添加 {"custom_fields": {"region": "cn-beijing", "env": "production"}}。自定义字段需在对接配置中预先定义，最多支持 10 个字段。

SIEM 对接的可用性依赖于客户网络环境与 SIEM 系统稳定性。平台提供对接健康检查功能，每 5 分钟发送一条心跳日志（action_name 为 heartbeat），用于验证连接是否正常。若连续 3 次心跳失败，平台将发送告警。客户需确保 SIEM 系统能够正确处理心跳日志，或配置忽略规则。对接配置的变更（如修改服务器地址）需重新测试连接，测试结果可在平台界面查看。

7. 常见审计场景示例

场景一：安全事件溯源。当发现可疑操作（如未授权访问敏感数据）时，安全管理员可通过审计日志查询特定时间范围内所有对敏感数据源的操作记录。例如，查询 2026-07-01 至 2026-07-07 期间，所有对 datasource-db-prod 的查询操作，并按 actor_id 分组统计。通过分析日志中的 actor_ip 与 detail 字段，可定位异常来源。该场景下，建议同时查询 API 调用日志与 Web 操作日志，以获取完整上下文。

场景二：合规审计报告。内审部门需定期生成操作审计报告，以证明平台操作符合内部政策。审计人员可导出指定时间范围内的所有审计日志，并使用第三方工具分析操作分布。例如，统计各操作类型的占比、各用户的操作频率、失败操作的分布等。报告可包含图表与摘要，平台不提供内置报告生成功能，但可通过 API 获取日志数据后自行生成。导出日志时需注意数据脱敏（如隐藏 actor_ip 后两位）。

场景三：权限变更追溯。当发现用户权限异常时，可查询该用户的所有角色绑定与解绑操作日志。例如，查询 actor_id 为 user-001 的日志，过滤 action_name 为 bind_role 或 unbind_role 的操作，并查看 detail 字段中的角色 ID 与操作时间。通过对比权限变更时间与异常行为时间，可判断权限变更是否为异常原因。该场景下，

建议同时查询角色本身的修改日志。

场景四：API 密钥滥用检测。若发现某个 API 密钥被异常高频调用，可查询该密钥对应的所有 API 调用日志。例如，查询 actor_type 为 api_key 且 actor_id 为 key-abc123 的日志，分析调用频率、请求路径及响应状态码。若发现大量 403 错误，可能表明密钥权限不足；若发现大量 200 成功但操作类型为删除，则需立即撤销密钥。该场景下，日志中的 actor_ip 字段可用于定位调用来源。

场景五：系统配置变更审计。当平台出现异常行为（如应用部署失败）时，可查询近期系统配置变更日志。例如，查询 action_category 为 config_management 的日志，查看修改了哪些配置项。通过对比配置变更时间与异常发生时间，可快速定位根因。该场景下，detail 字段中的 old_values 与 new_values 提供了变更前后的具体值，便于回滚决策。

场景六：跨租户操作审计（仅限多租户场景）。超级管理员可查询所有租户的审计日志，用于发现跨租户的异常操作。例如，查询某个租户的管理员是否尝试访问其他租户的资源（通过 resource_id 判断）。该场景下，日志中的 tenant_id 字段（仅在多租户场景存在）用于区分租户。超级管理员的查询行为本身也会被记录，确保审计链完整。

8. 附录：字段速查

本附录提供审计日志所有字段的速查表，包括字段名、类型、是否必填、说明及示例值。字段名按字母顺序排列，便于快速定位。字段类型包括 string、number、boolean、object 及 array。所有字段均为 UTF-8 编码，时间戳为 Unix 毫秒时间戳（UTC）。字段速查表可在平台文档中下载 CSV 版本，或通过 API 获取最新定义。

字段速查表（部分）：log_id (string, 必填, 全局唯一标识, 示例: a1b2c3d4-e5f6-7890-abcd-ef1234567890); timestamp (number, 必填, 毫秒级 UTC 时间戳, 示例: 1719792000000); actor_id (string, 必填, 执行者 ID, 示例: user-001); actor_ip (string, 必填, 执行者来源 IP, 示例: 192.168.1.100); actor_type (string, 必填, 执行者类型: user/api_key/system, 示例: user); resource_id (string, 必填, 操作资源 ID, 示例: app-123); resource_type (string, 必填, 资源类型, 示例: application); action_category (string, 必填, 操作领域, 示例: application_management); action_type (string, 必填, 操作类型, 示例: modify); action_name (string, 必填, 操作名称, 示例: modify_app_config); result (string, 必填, 操作结果: success/failure/denied, 示例: success); detail (object, 可选, 操作详情, 示例: {"changed_fields":["timeout"]})。

字段速查表（续）：tenant_id (string, 可选, 仅多租户场景, 租户 ID, 示例: tenant-001); request_id (string, 可选, 仅 API 调用场景, 请求 ID, 示例: req-abc123); duration_ms (number, 可选, 仅 API 调用场景, 请求耗时毫秒, 示例: 150); user_agent (string, 可选, 仅 Web 操作场景, 用户代理字符串, 示例: Mozilla/5.0...); sdk_version (string, 可选, 仅 SDK 场景, SDK 版本号, 示例: 2.6.0); device_fingerprint (string, 可选, 仅 SDK 场景, 设备指纹, 示例: fp-xyz789); custom_fields (object, 可选, 自定义字段, 示例: {"region":"cn-beijing"})。

字段速查表（Syslog 映射）：Syslog 字段与平台字段的映射关系如下：TIMESTAMP -> timestamp; HOSTNAME -> 平台域名; APP-NAME -> actor_type; PROCID -> actor_id; MSGID -> action_name; STRUCTURED-DATA -> detail (序列化为 JSON 字符串); MSG -> 其余字段拼接。映射规则可在 Syslog 对接配置中调整，但需确保 SIEM 端解析规则一致。Syslog 消息的 FACILITY 默认为 local0，SEVERITY 根据 result 字段映射：success -> 6 (Informational), failure -> 3 (Error), denied -> 4 (Warning)。

字段速查表（导出格式）：导出为 CSV 时，字段顺序与速查表一致，字段名作为表头。detail 字段在 CSV 中被序列化为 JSON 字符串，并用双引号包裹。导出为 JSON 时，每条日志为一行 JSON 对象（JSON Lines 格式）。导出文件包含元数据行（以 # 开头），记录导出时间、查询条件及日志总数。元数据行示例：# Exported at 2026-07-15T10:00:00Z, query: action_category=user_management, total: 1234。

字段速查表（变更历史）：字段定义可能随产品版本更新而变更，变更历史记录在平台文档的变更日志中。当前版本（v2.6）新增了 device_fingerprint 与 custom_fields 字段，删除了 deprecated 的 source 字段。客户在升级版本前应查阅变更日志，确保 SIEM 解析规则兼容。字段的废弃会提前至少一个版本通知，并在日志中保留该字段（值为 null）直至完全移除。

获取盖章版 / 完整问卷 / 定制差距分析

访问 blockhub.club 信任与合规中心，或预约演示联系客户成功经理。请随附本 PDF 文档编号以便版本核对。